



Comparison of GDPR v selected Middle East Privacy Laws

Dear Reader,

Thank you for downloading this White Paper. Its aim is to help organisations who operate within different GCC jurisdictions in comparing and aligning with different data protection obligations.

Please note that various colours have been used to indicate key similarities between chosen data protection laws. The only exception is the **red colour** which highlights major differences that should particularly be taken into account.

	EU	UAE (Federal Law)	DIFC	ADGM	KSA	Qatar	Oman	Bahrain	WLC Remarks
Name of Legislation	General Data Protection Regulation (GDPR)	UAE Law on the Protection of Personal Data	DIFC Data Protection Law	Data Protection Regulations 2022 *Amendments to the law in 2022, 2023, and 2024	Personal Data Protection Law (PDLP)	Law No.13 of 2016 Personal Data Privacy Protection	Personal Data Protection Law	Law No. (30) of 2018 with Respect to Personal Data Protection Law	
Regulations	N/A	Executive Regulations	Data Protection Regulations 2020	N/A	Implementing Regulation of the Personal Data Protection Law	N/A	Executive Regulation of the Personal Data Protection Law	10 ministerial resolutions to the Personal Data Protection Law	
Effective Date	Came into force: 24 May 2016 Is enforced from: 25 May 2018	Came into force: 2 January 2022 Is enforced from: within 6 months after Executive Regulations are published (the UAE Data Office reserves the right to extend the enforcement date and as of now, they have not yet been published)	Came into force: 1 July 2020 Is enforced from: 1 October 2020	Came into force: 14 February 2021 Is enforced from: • for entities incorporated on or after the 14 February 2021 – from 14 August 2021 • for other entities – from 14 February 2022.	Came into force: 14 September 2023 Is enforced from: 14 September 2024	Came into force: 29 January 2017 Is enforced from: 29 January 2018	Came into force: 23 February 2023 Becomes fully enforceable: 5 February 2026	Came into force and is enforced: 1 August 2019	



Scope

	EU	UAE (Federal Law)	DIFC	ADGM	KSA	Qatar	Oman	Bahrain	WLC Remarks
Territorial Scope	Applies to a controller or processor that: 1. is established in the EU 2. offers goods or services in the EU 3. monitors the behaviour of EU data subjects.	Applies to: 1. each data subject residing in the state or having a place of business in it 2. each controller or processor residing in the state and carrying out the activities of processing personal data of data subjects inside and outside the state 3. each controller or processor residing outside the state and carrying out the activities of processing personal data of data subjects inside the state.	Applies to a controller or processor that: 1. is established in DIFC regardless where the processing takes place 2. processes personal data in DIFC as part of stable arrangements, other than on an occasional basis (law applies to such processing only).	Applies to: 1. a controller or processor that is established in ADGM regardless where the processing takes place 2. a processor who is processing personal data for a controller outside of ADGM.	Applies to a controller or processor that processes personal data related to individuals that takes place in the KSA by any means, including the processing of personal data related to individuals residing in the Kingdom by any means from any party outside the Kingdom.	Does not explicitly define the territorial scope. It should be assumed that it applies to a controller or processor that processes personal data related to individuals residing in Qatar.	The law does not directly determine the territorial scope. It should be assumed that it applies to a controller or processor that processes personal data related to individuals residing in Oman.	Applies to every controller or processor (including explicitly natural persons) that: 1. is habitually resident in the Kingdom or maintains a place of business in the Kingdom 2. is not habitually resident nor maintains a place of business in the Kingdom, but processes data by using means situated in the Kingdom, unless such means are used only for purposes of transit of data over the Kingdom's territory.	Each privacy law either explicitly establishes or can be interpreted to have extraterritorial applicability. Among them, KSA seems to have the broadest scope, as it extends to any means of data processing and applies to any entity outside KSA that processes personal data related to individuals within the Kingdom.
Material scope	Applies to the processing of personal data wholly or partly by automated means and to the processing other than by automated means of personal data which form part of a filing system or are intended to form part of a filing system.	Applies to the processing of all or part of the personal data by means of electronic systems which operate automatically, or by other means.	Applies to the processing of personal data by automated means, and other than by automated means where the personal data forms part of a Filing System or is intended to form part of a filing system.	Processing of personal data wholly or partly by automated means and to the processing other than by automated means of personal data which forms part of a filing system or is intended to form part of a filing system.	Applies to any processing of personal data related to individuals by any means. This includes data of the deceased if it would lead to them or a member of their family being identified specifically.	Applies to personal data processed electronically, or personal data obtained, gathered or extracted in preparation in any other way for electronic processing, or when processed via a combination of electronic and traditional processing.	Applies to any personal data being processed.	Applies to processing of personal data by total or partial automatic means and processing of by non-automatic means of personal data which form part of a filing system or are intended to form part of a filing system.	KSA and UAE Federal Law have the broadest scope of application – they apply to any type of processing, and do not narrow down the scope depending on whether personal data is to form part of a filing system.
Notable exemptions	Personal or household activities.	1. Government Data 2. Governmental entities which control or process personal data 3. Personal data held by the security and judicial authorities 4. A data subject who processes his/her data for personal purposes 5. Personal Health Data that has legislation regulating its protection and processing 6. Personal banking and credit data and information that have legislation regulating their protection and processing 7. Companies and establishments located in free zones in the Country and have special legislations regarding Personal data protection.	Operations or sets of operations performed on personal data by: 1. a natural person in the course of a purely personal or household activity that has no connection to a commercial purpose 2. law enforcement authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including safeguarding against and preventing threats to public security.	1. Personal or household activities 2. Public authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to national security 3. Files or sets of files, as well as their cover pages, which are not structured according to specific criteria.	Personal or family use, as long as the data subject did not publish or disclose it to others.	1. Personal or household activities 2. Personal data processed for the purpose of obtaining official statistical data.	1. Protecting national security or public interest 2. Implementation of the units of the administrative apparatus of the state and other public legal persons 3. Implementation of a legal obligation imposed on the controller by virtue of any law, judgment or decision by the court 4. Protection of the economic and financial interests of the state. 5. Protection of a vital interest of the personal data subject 6. Detection or prevention of any criminal offense based on an official written request from the investigation entities 7. Execution of a contract to which the personal data subject is a party 8. Personal or family sphere 9. Historical, statistical, scientific, literary, or economic research conducted by entities authorised to perform such works, provided that any indication or reference relating to the personal data subject shall not be used in published research or statistics to ensure that personal data is not attributed to an identified or identifiable natural person 10. If the data is available to the public in a manner that is not contrary to the provisions of this law.	1. Purposes of individual's personal or family affairs 2. Processing operations concerning public security handled by the Ministry of Defense, Ministry of Interior, National Guard, National Security Service, or other security body in the Kingdom.	Every single legislation has its own set of exceptions. They are pretty much very similar, but it is crucial to take into account minor differences (for instance, please see the red markings re. personal use, which highlight differences between data protection laws).
Definition of personal data (or equivalent term)	Any information relating to an identified or identifiable natural person ("data subject"); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.	Any data relating to an identified natural person, or a natural person who can be identified, directly or indirectly, through the linking of data, by reference to an identifier such as his or her name, voice, picture, identification number, electronic identifier, geographical location, or one or more physical, physiological, cultural or social characteristics.	Any information referring to an identified or identifiable natural person. Identifiable natural person means a natural living person who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to his biological, physical, biometric, physiological, mental, genetic, economic, cultural or social identity (and "identified natural person" is interpreted accordingly).	Any information relating to a data subject. 'Data subject' means an identified or identifiable living natural person; an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.	Any data, regardless of its source or form, that may lead to identifying an individual specifically, or that may directly or indirectly make it possible to identify an individual, including name, personal identification number, addresses, contact numbers, license numbers, records, personal assets, bank and credit card numbers, photos and videos of an individual, and any other data of personal nature.	Any data of an individual whose identity is defined or can be reasonably defined whether through such Personal Data or through the combination of such data with any other data.	Data that directly or indirectly makes a natural person identified or identifiable by referring to one or more identifiers such as the name, civil identity number, Electronic IDs data, spatial data, or by referring to one or more factors related to genetic, physical, mental, psychological, social, cultural or economic identity.	Any information in any form concerning an identified individual, or an individual who can, directly or indirectly, be identified by reference, in particular, to his or her personal identification number, or by reference to one or more factors specific to his or her physical, physiological, intellectual, cultural, economic, or social identity. In determining whether an individual is identifiable, all the means that the data controller or any other person uses or may have access to should be taken into consideration.	In every single jurisdiction compared herein, the term is interpreted alike which helps larger organisation to have a uniform baseline and approach under different jurisdictions.

Comparison of GDPR v selected Middle East Privacy Laws									
	SCOPE	SPECIAL CATEGORIES OF DATA	DATA SUBJECTS RIGHTS	MISCELLANEOUS	DPO	DATA BREACH	ENFORCEMENT		
	EU	UAE (Federal Law)	DIFC	ADGM	KSA	Qatar	Oman	Bahrain	WLC Remarks
Data outside the scope of personal data (or equivalent term)	Anonymous data is information which does not relate to an identified or identifiable natural personal of personal data rendered anonymous in such a manner that the data subject is not or no longer identifiable.	Anonymous data which is processed in a manner that leads to the anonymity of the Data subject, not linking and attributing such data to him/her and the inability to identify him/her in any way whatsoever.	Anonymousised so that the data is no longer personal data and no Data subject can be identified from the data including where the data is lost, damaged or accidentally released.	Anonymous data which is no longer personal data and no data subject can be identified from the data.	Anonymous data is data which does not possess direct and indirect identifiers that would otherwise indicate the identity of the data subject. Anonymisation makes data permanently impossible to identify the data subject.	Does not explicitly mention anonymous data but it may be assumed that it is data which does not relate to an identified or identifiable natural personal; data processed in such a manner that the data subject is not or no longer identifiable.	Mention anonymous data in Executive Regulations. It is data which does not relate to an identified or identifiable natural personal; data processed in such a manner that the data subject is not or no longer identifiable	Mentions anonymous data under Article 3(5). It is data which does not relate to an identified or identifiable natural personal; data processed in such a manner that the data subject is not or no longer identifiable.	Under all privacy laws, data that was anonymized should not be considered personal data as it lacks any identifiers that would uncover data subject identity.
Processing Bases (Regular personal data)	1. Consent for one or more specific purposes 2. Processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract 3. Processing is necessary for compliance with a legal obligation to which the controller is subject 4. Processing is necessary in order to protect the vital interests of the data subject or of another natural person 5. Processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller 6. Processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party.	1. Consent 2. If the processing is necessary to protect public interest 3. If the processing is related to personal data which has become available and known to all by an act of the Data subject 4. If the processing is necessary to initiate any procedures of legal claim or defense of rights or is related to judicial or security procedures 5. If the processing is necessary for purposes of occupational or preventive medicine in order to assess the employees' ability of to work, performing medical diagnosis, providing health or social care, treatment or health insurance services, managing health or social care systems and services in accordance with the legislation in force in the State 6. If the processing is necessary to protect public health, including protection from existing diseases and epidemics, or for the purposes of ensuring the safety and quality of healthcare, medicines, drugs and medical devices, in accordance with the legislation in force in the State 7. If the processing is necessary for archival purposes or for scientific, historical and statistical studies in accordance with the legislation in force in the State 8. If the processing is necessary to protect the interests of the Data subject 9. If the processing is necessary for the purposes of the controller or Data subject carrying out their obligations and exercising their legally established rights in the field of employment, social security or laws concerned with social protection, to the extent permitted by such Laws 10. If the processing is necessary to perform a contract to which the Data subject is a party, or to take measures at the request of the Data subject with the aim of concluding, amending or terminating a contract 11. If the processing is necessary to fulfil specific obligations stipulated in other laws in force in the State for the controller 12. Any other cases set out in the Executive Regulations of this Decree by Law.	1. Consent 2. Processing is necessary for the performance of a contract to which a data subject is a party, or in order to take steps at the request of a data subject prior to entering into such contract 3. Processing is necessary for compliance with Applicable Law that a controller is subject 4. Processing is necessary in order to protect the vital interests of a Data subject or of another natural person 5. Processing is necessary for performance of a task carried out by a DIFC Body in the interests of the DIFC; exercise of a DIFC Body's powers and functions; or the exercise of powers or functions vested by a DIFC Body in a Third Party to whom personal data is disclosed by the DIFC Body 6. Processing is necessary for the purpose of legitimate interests pursued by a controller or Third Party to whom the personal data has been made available, subject to Article 13.	1. Consent 2. Processing is necessary for the performance of a contract to which the Data subject is a party or in order to take steps at the request of the Data subject prior to entering into a contract 3. Processing is necessary for compliance with a legal obligation to which the controller is subject under Applicable Law 4. Processing is necessary to protect the vital interests of the Data subject or of another natural person 5. Processing is necessary for the performance of a task carried out by a public authority in the interests of ADGM; or in the exercise of (i) ADGM's; (ii) the Financial Services Regulatory Authority's; (iii) the ADGM Court's; or (iv) the Registration Authority's functions or in the exercise of official authority vested in the controller under Applicable Law or 6. Processing is necessary for the purposes of the legitimate interests pursued by the controller or by a Third Party.	1. Consent 2. If the processing serves actual interests of the Data subject, but communicating with the Data subject is impossible or difficult 3. If the processing is pursuant to another law or in implementation of a previous agreement to which the Data subject is a party 4. If the controller is a Public Entity and the processing is required for security purposes or to satisfy judicial requirements 5. If the processing is necessary for the purpose of legitimate interest of the controller.	1. Consent 2. Processing is necessary to achieve a Lawful Purpose for the Controller or the other recipient of such data.	1. Consent.	1. Consent 2. Performance of a contract with the data subject 3. Processing is necessary for taking steps at the request of the data subject with the purpose of entering into a contract 4. Processing is necessary for the compliance with any legal obligation, other than an obligation imposed by contract, or the compliance with orders issued by a competent court or the Public Prosecution 5. Processing is necessary for protecting the vital interests of the data subject 6. Processing is necessary for Pursuing the legitimate interests of the Data Controller or any third party to whom personal data has been disclosed to, provided that it is not in conflict with fundamental rights and freedoms of the data subject.	Under each data protection law, the bases for data processing are quite similar – the broadest ones yet stem from UAE Federal Law and might be even extended by Regulations.



Special categories of data

	EU	UAE (Federal Law)	DIFC	ADGM	KSA	Qatar	Oman	Bahrain	WLC Remarks
Health Data	YES	YES	YES	YES	YES	YES	YES	YES	1. DIFC law also lists 'communal origin' as a type of sensitive data. 2. UAE Data Law also lists 'data that reveals a natural person's family' as sensitive data. 3. UAE Data Laws specifies also 'physical, psychological, mental, genetic or sexual condition' as sensitive data. 4. KSA Law includes 'data that indicates that one or both of the individual's parents are unknown.' 5. Qatar Data Protection Law lists physical or psychological condition as well as marital status as sensitive personal data. 6. Oman specifies data related to security measures as sensitive data.
Genetic Data	YES	NOT EXPLICITLY MENTIONED	YES	YES	YES	NO	YES	NO	
Biometric Data	YES	YES	YES	YES	YES	NO	YES	NO	
Race or ethnicity	YES	YES	YES	YES	YES	YES	YES	YES	
Religious beliefs	YES	YES	YES	YES	YES	YES	YES	YES	
Philosophical beliefs	YES	YES	YES	YES	YES	NO	NO	YES	
Political opinions	YES	YES	YES	YES	YES	NO	YES	YES	
Sex life or orientation	YES	YES	YES	YES	YES	NO	YES	YES	
Citizenship or immigration status	NO	NO	NO	YES	NO	NO	NO	NO	
Offenses and criminal convictions	NO *some extra rules apply	YES	YES	YES	YES	YES	YES	YES	
Trade union membership	YES	YES	YES	NO	NO	NO	NO	YES	
Precise geolocation	NO	NO	NO	NO	NO	NO	NO	NO	
SSN, driver's license, state ID or passport no.	NO	NO	NO	NO	NO	NO	NO	NO	
Mail, email or SMS content	NO	NO	NO	NO	NO	NO	NO	NO	
Children's data	NO	NO	NO	NO	NO	YES	NO	NO	



Specific requirements for Sensitive Data

	EU	UAE (Federal Law)	DIFC	ADGM	KSA	Qatar	Oman	Bahrain	WLC Remarks
	May not be processed unless one of the exceptions apply: 1. ● explicit consent from the data subject, unless prohibited by Union or Member State law 2. ● <u>processing necessary for employment, social security, or social protection law</u>, with appropriate legal authorization or collective agreements 3. ● protection of vital interests of incapable data subjects or others 4. ● <u>processing by non-profit bodies for their legitimate activities, limited to members or individuals with regular contact, with safeguards and no external disclosure without consent</u> 5. ● <u>processing of data publicly made by the data subject</u> 6. processing necessary for legal claims or judicial proceedings 7. processing for substantial public interest, proportionate to the aim, respecting data protection rights, and with specific safeguards 8. ● <u>processing for preventive or occupational medicine, health care provision, or management, subject to legal or contractual conditions and safeguards</u> 9. ● <u>processing for public health interests, ensuring rights and freedoms of data subjects</u> 10. processing for archiving, scientific, historical research, or statistical purposes, in accordance with proportionate Union or Member State law, and safeguarding data subject rights and interests.	Where processing is carried out on a large scale with regard to sensitive personal data, the controller and/or processor must complete a DPIA and designate a DPO.	May not be processed unless one of the exceptions apply: 1. ● explicit consent from the Data subject is obtained for processing Special Categories of Personal data for specific purposes 2. ● <u>processing is necessary for fulfilling employment-related obligations and rights</u>, including recruitment, employment contracts, and pension schemes 3. ● <u>processing is necessary to protect the vital interests of a Data subject</u> incapable of giving consent 4. ● <u>non-profit organizations can process Personal data of their members or individuals in regular contact</u>, ensuring data confidentiality 5. ● <u>processing relates to Personal data made public by the Data subject</u> 6. ● <u>processing is necessary for legal claims or court proceedings</u> 7. processing is required to comply with specific legal obligations, with notice provided to the Data subject where feasible 8. processing is necessary to comply with anti-money laundering, counter-terrorist financing, or crime prevention laws 9. ● processing is needed for healthcare purposes, subject to professional secrecy obligations 10. processing is required to protect the public against misconduct in various service sectors 11. processing is necessary to mitigate potential bias or inaccurate decision-making 12. processing is necessary for substantial public interest reasons, with appropriate safeguards for Data subject rights.	May not be processed unless one of the exceptions apply: 1. ● <u>data subject's explicit consent</u> is given for specified purposes 2. ● <u>processing is necessary for fulfilling obligations or exercising specific rights under employment law</u>, with an appropriate policy document in place 3. ● <u>processing is necessary to protect the vital interests of the data subject or another person</u> incapable of giving consent 4. ● <u>processing is necessary for health-related purposes, including medical treatment</u>, by health professionals under confidentiality obligations 5. ● <u>processing is necessary for public health interests</u>, such as protecting against health threats 6. processing is necessary for archiving and research purposes in compliance with applicable law 7. ● <u>processing is for legitimate activities by non-profit bodies, solely for members</u>, with data not disclosed without consent 8. ● <u>processing is allowed for data intentionally made public by the data subject</u> 9. processing is necessary for contract performance or at the data subject's request 10. ● <u>processing is necessary for legal claims or when courts are acting judicially</u> 11. processing is necessary for various public interest reasons, with an appropriate policy document in place, covering diverse scenarios as outlined in the Law.	May only be processed if: 1. based on the ● <u>data subject's explicit consent</u> 2. if the processing is pursuant to another law or in implementation of a previous agreement to which the Data subject is a party 3. ● <u>the processing serves actual interests of the data subject</u>, but communicating with the data subject is impossible or difficult 4. if the controller is a public entity and the processing is required for security purposes or to satisfy judicial requirements.	Personal Data of a special nature may only be processed after obtaining the permission from the Competent Department, as per the measures and controls determined by a decision issued by the Minister.	May not be processed unless if a permit from the Ministry of Transport, Communications and Information Technology has been obtained.	Processing of sensitive personal data is prohibited ● <u>without data subject's consent</u> unless: 1. processing is necessary for the purposes of carrying out the obligations and rights of the data controller in the employment field 2. processing is necessary to ● <u>protect any individual, where the data subject or the data subject's custodian, legal guardian, or conservator, is legally incapable of giving his or her consent</u>, subject to obtaining the Authority's prior approval 3. ● <u>processing relates to data which is made available to the public, by the data subject</u> 4. ● <u>processing is necessary for pursuing any legal claims or defenses, including the needed preparations thereof</u> 5. processing that is necessary for the purposes of ● <u>preventive medicine, medical diagnosis, provision of healthcare or treatment, or for the management of healthcare services which is carried out by a licensed member of a medical profession, or by any other person who is bound by a duty of confidentiality as imposed by law</u> 6. processing carried out in the course of ● <u>activities of associations, of all kinds, unions and other non-profit-seeking bodies</u>, if specific requirements are met. 7. processing is carried out by a competent public body to the extent necessary to carry out its legitimate duties as laid down by virtue of a law 8. processing of data relating to racial, ethnic, or religious origins where the processing is necessary for the purpose of identifying the existence or absence of equality of opportunity or treatment between members of the society of different racial or ethnic or religious origins, provided that such processing is carried out with appropriate safeguards for the rights and freedoms of data subjects as prescribed by law.	Comparing different privacy laws, one can spot that except for UAE Federal Law, none of the laws allows the data to be processed for legitimate interest.



Data Subjects Rights

	EU	UAE (Federal Law)	DIFC	ADGM	KSA	Qatar	Oman	Bahrain	WLC Remarks
Right to be informed	YES	YES	YES	YES	YES	YES	YES	YES	
Right of access	YES	YES	YES	YES	YES	YES	YES	YES	
Right to rectify	YES	YES	YES	YES	YES	YES	YES	YES	
Right to have data erased	YES	YES	YES	YES	YES	YES	YES	YES	
Right to restrict	YES	YES	YES	YES	YES	NO	NO	YES	Omani law provides a right to block personal data, which can be assumed to reflect other legislation's right to restrict.
Right to object	YES	YES	YES	YES	YES	YES	YES	YES	
Right not be subject to a decision based solely on automated processing	YES	YES	YES	YES	YES	NO	NO	YES	Rather than the right 'not to be subject', UAE Data Law and DIFC Law provide the 'right to object to any decisions resulting from automated processing, including profiling'.
Right to appeal decision	YES	NO	YES	YES	NO	NO	NO	YES	
Right to data portability	YES	YES	YES	YES	YES	NO	YES	NO	
Deadline for response	1 month (+2 months extension).	No specific timeline given.	In case of access request, response should be provided within 1 month (+2 months extension).	Without undue delay and in any event within 2 months of receipt of the request (can be extended +1 month).	Without undue delay and within a period of 30 days (can be extended to +30 days).	Within a period of 30 calendar days. At the same time, controllers are allowed to take an extra two months to respond to a request in case it is complex.	Within a period of maximum 45 days of receipt of the request (not specifies any potential extensions).	Within a period of maximum 15 days. A data controller, within a period not exceeding 10 days may notify the applicant to complete any deficiency in his/her request.	



Miscellaneous

	EU	UAE (Federal Law)	DIFC	ADGM	KSA	Qatar	Oman	Bahrain	WLC Remarks
Special requirements for children's data	A controller must obtain parental consent if relying on consent to process data of children under 13-16 in relation to an offer of information society services directly to the child.	Not specified.	Not particularly addressed. However, the exemptions related to automated decision making, including profiling do not apply if the data subject in question is a minor (by reference to the legal age of majority in the United Arab Emirates from time to time).	No specific requirements set to controller, but the law states that processing is lawful only if and to the extent that, among other things, processing is necessary for the purposes of legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests of the data subject which require protection of personal data, in particular where the data subject is a child.	Not specified.	The law mentions special obligations that controllers need to comply with when they operate website addressing children, such as being publicly transparent about processing children's personal data and obtaining explicit consent from the guardian etc.	The processing of children's data shall be prohibited unless there is an approval of his/her guardian.	Not specified.	
PIAs & DPIAs	Controllers must conduct data protection impact assessments for processing that is likely to result in a high risk to data subjects' rights and freedoms, including (a) automated decision making, (b) processing of sensitive data on a large scale, (c) systematic monitoring of a publicly accessible area on a large scale.	Organisations must conduct a formal assessment of necessity, proportionality, risks, and risk reduction measures when processing personal data in certain circumstances, especially when: 1. employing technology likely to pose high risks to the privacy and confidentiality of personal data 2. processing large volumes of sensitive personal data.	Prior to undertaking high-risk processing activities a controller are under obligation to carry out an assessment of the impact of the proposed processing operations on the protection of personal data, considering the risks to the rights of the data subjects concerned. A controller may also elect to carry out such assessment in relation to the processing of personal data that is not a high-risk processing activity.	Controllers must, prior to processing that is likely to result in a high risk to the rights of natural persons, carry out an assessment of the impact of the envisaged processing operations on the protection of personal data.	A controller shall conduct an impact assessment of personal data processing in relation to any product or service in the following cases: 1. processing of Sensitive Data 2. collecting, comparing, or linking two or more sets of Personal data obtained from different sources 3. continuous and large-scale processing of Personal data of individuals lacking legal capacity, or operations requiring continuous monitoring of Data subjects, or processing Personal data using new technologies, or making decisions based on automated processing of Personal data 4. providing a product or service involving processing Personal data likely to cause serious harm to the privacy of Data subjects.	Controllers shall review privacy protection measures before proceeding with new processing operations. Especially important is to conduct a DPIA, where controller is carrying out a processing activity that "may cause serious damage" to the individuals whose personal data is being processed. Guidelines on conducting DPIAs for Qatar are available through the link .	The law does not explicitly mention these assessments, but it stipulates that it is controller's obligation to identify risks that the personal data subject may be exposed to as a result of the processing.	The law does not explicitly mention these assessments, however, according to resolution issues by Ministry of Justice, Islamic Affairs, and Waqf of Bahrain in 2022 , controller may conduct the data protection impact assessment, taking into account the nature, scope, context and purposes of the processing, and high risks of processing on the rights and freedoms of natural persons. A single assessment may address a set of similar processing operations that present similar high risks.	Even if not explicitly mentioned, it should be assumed that DPIA is a primary obligation for all controllers undertaking any high-risk processing activities.
DPAs	Processing by a processor shall be governed by a contract or other legal act under Union or Member State law, that is binding on the processor with regard to the controller and that sets out the subject-matter and duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects and the obligations and rights of the controller.	When a processor conducts processing in accordance with the controller's instructions, an agreement must be established between them. This agreement should specify the scope, subject, purpose, nature, and type of Personal data, as well as the category of the Data subject. If not in place, the processor shall be deemed responsible, jointly with the controller, for the obligations and responsibilities contained in the Law.	Where processing is to be carried out on behalf of a controller by a processor, the processing shall be governed by a legally binding written agreement between the controller and the processor.	Processing by a processor must be governed by a contract or other legal act, that is binding on the processor with regard to the controller and that sets out the subject-matter and duration of the processing, the nature and purpose of the processing, the type of Personal data and categories of data subjects and the obligations and rights of the controller.	The controller must ensure that any selected processor provides adequate safeguards for safeguarding Personal data. The agreement with the processor should cover various aspects, including the purpose of processing, types of Personal data involved, duration of processing, notification procedures for Personal data Breaches, compliance with regulations in other countries, mandatory disclosure requirements under applicable laws, and identification of subcontractors or third parties involved in processing Personal data.	The controller must verify processor's compliance with the instructions of the controller and thus take the appropriate precautions to protect Personal Data, and monitoring and following-up the same constantly.	The law does not provide information about data processing agreements. However, the controller is obliged to evaluate the level of protection provided by the external processing entity and assess the risks associated with transferring personal data abroad.	The law mandates a written DPA between the controller and the processor.	Under each data protection law, a DPA is mandatory, but the subtle differences should be in each case taken into account.

Data Protection Officer (DPO)

	EU	UAE (Federal Law)	DIFC	ADGM	KSA	Qatar	Oman	Bahrain	WLC Remarks
Designation	The DPO needs to be appointed in cases where: 1. the processing is carried out by a public authority or body, except for courts acting in their judicial capacity 2. the core activities of the controller or the processor consist of processing operations which, by virtue of their nature, their scope and/or their purposes, require regular and systematic monitoring of data subjects on a large scale or 3. the core activities of the controller or the processor consist of processing on a large scale of special categories of data pursuant to https://gdpr-info.eu/art-9-gdpr Article 9 or personal data relating to criminal convictions and offences referred to in Article 10.	The controller and processor shall appoint a Data Protection Officer in any of the following cases: 1. if processing would cause a high-level risk to the confidentiality and privacy of the Personal data of the Data subject as a result of adopting new technologies or with regard to the volume of data 2. if processing would involve a systematic and comprehensive assessment of Sensitive Personal data, including Profiling and Automated processing 3. if processing would be carried out on a large volume of Sensitive Personal data.	A DPO shall be appointed by: 1. DIFC bodies, other than the courts acting in their judicial capacity; and 2. a controller or processor performing High risk processing activities on a systematic or regular basis.	The controller and the processor must appoint a person to perform the tasks listed in section 37 where: 1. the processing is carried out by a public authority, except for courts acting in their judicial capacity 2. the core activities of the controller or the processor consist of processing operations which, by virtue of their nature, scope and purposes, require regular and systematic monitoring of Data subjects on a large scale 3. the core activities of the controller or the processor consist of processing on a large scale of Special Categories of Personal data.	The controller shall appoint one or more individuals to be responsible for the protection of Personal data in any of the following cases: 1. controller is a public entity that provides services involving processing of personal data on a large scale 2. primary activities of the controller consist of processing operations that require regular and continuous monitoring of individuals on a large scale 3. core activities of the controller consist of processing sensitive personal data.	There is currently no obligation for the organisations to appoint a DPO.	The controller is obliged to appoint a DPO in all cases.	The law does not regulate appointment of Data Protection Guardians (Bahrain version of DPOs) – such appointment is not mandatory, unless there is a resolution of the Board which mandates such appointment for certain categories of controllers. In all cases, where the Data Protection Guardian has been appointed, the controller must notify the Authority within three working days.	There is a subtle difference regarding appointment obligation in the: 1. KSA, where it does not need to be a large scale processing of sensitive personal data to trigger the appointment obligation. 2. UAE, where the appointment obligation wording is different and focuses more on high-risk activities.
Tasks	The data protection officer shall have at least the following tasks: 1. to inform and advise the controller or the processor and the employees who carry out processing of their obligations pursuant to this Regulation and to other Union or Member State data protection provisions 2. to monitor compliance with this Regulation, with other Union or Member State data protection provisions and with the policies of the controller or processor in relation to the protection of personal data, including the assignment of responsibilities, awareness-raising and training of staff involved in processing operations, and the related audits 3. to provide advice where requested as regards the data protection impact assessment and monitor its performance pursuant to Article 35 4. to cooperate with the supervisory authority 5. to act as the contact point for the supervisory authority on issues relating to processing, including the prior consultation referred to in Article 36, and to consult, where appropriate, with regard to any other matter.	The Data Protection Officer shall, in particular, undertake the following tasks and powers: 1. verifying the quality and correctness of the procedures in place at the controller and the processor 2. receiving requests and complaints related to personal data in accordance with provisions of this decree-law and its executive regulations 3. providing technical advice on evaluation procedures and periodic examination of personal data protection systems and intrusion prevention systems at the controller and processor, documenting the results of such evaluation and providing appropriate recommendations in this regard, including risk assessment procedures 4. acting as a link between the controller or the processor, as the case may be, and the bureau regarding the application of personal data processing provisions stipulated in this decree by law 5. any other tasks or powers which are determined in accordance with the Executive Regulations of this decree by law.	A DPO shall perform at least the following tasks: 1. monitor a controller or processor's compliance with: (i) this Law; (ii) any other data protection or privacy-related laws or regulations to which the organisation is subject within the DIFC; and (iii) any policies relating to the protection of Personal data, including the assignment of responsibilities, awareness-raising and training of staff involved in processing operations, and the related audits 2. inform and advise a controller or processor and its employees who carry out processing of its obligations pursuant to this Law and to other data protection provisions, including where the organisation is subject to overseas provisions with extra-territorial effect 3. provide advice where requested in relation to data protection impact assessments undertaken pursuant to Article 20 4. cooperate with the Commissioner in accordance with Article 17(3) 5. act as the contact point for the Commissioner on issues relating to processing 6. receive and act upon any relevant findings, recommendations, guidance, directives, resolutions, sanctions, notices or other conclusions issued or made by the Commissioner.	The tasks of the Data Protection Officer include: 1. to inform and advise the controller or the processor and the employees who carry out processing of their obligations pursuant to these Regulations and to other data protection provisions under Applicable Law 2. to monitor compliance with these Regulations, with other data protection provisions under Applicable Law and with the policies of the controller or processor in relation to the protection of Personal data, including the assignment of responsibilities, awareness-raising and training of Staff involved in processing operations, and the related audits 3. to provide advice where requested as regards the Data Protection Impact Assessment and monitor its performance pursuant to section 34 4. to cooperate with the Commissioner of Data Protection; and 5. to act as the contact point for the Commissioner of Data Protection on issues relating to processing and to consult with the Commissioner of Data Protection, where appropriate, with regard to any other matter.	The responsibilities include: 1. monitoring the implementation of the provisions of the Law and its Regulations 2. overseeing the procedures adopted by the controller 3. receiving requests related to Personal data in accordance with the provisions of the Law and its Regulations 4. acting as the direct point of contact with the competent authority and implementing its decisions and instructions regarding the application of the provisions of the law and its regulations 5. supervising the impact assessment procedures, audit reports, and evaluations related to Personal data protection controls, documenting the assessment results, and issuing necessary recommendations accordingly 6. enabling the Data subject to exercise their rights as stipulated in the Law 7. notifying the Competent Authority of Personal data Breach incidents 8. responding to requests from data subjects and addressing complaints filed by them in accordance with the provisions of the Law and its Regulations 9. monitoring and updating the records of Personal data processing activities of the controller 10. handling the controller's violations related to Personal data and taking corrective actions accordingly.	N/A.	The DPO shall have the following tasks: 1. submitting proposals and consultations to the controller or processor in relation to their obligation stipulated in the law and this regulation 2. following up on the implementation of the policies of the controller or processor relating to the protection of personal data 3. following up the implementation by the controller or processor of their obligations stipulated in the law and this regulation 4. coordinating with the Competent Department in matters relating to the processing of personal data.	The Data Protection Guardian shall have the following tasks: 1. assisting the data controller in exercising his rights and adhering to his duties as prescribed under the provisions of the data protection law 2. liaise between the Authority and controller with respect to the data controller's implementation of specific provisions related to the processing of personal data 3. ensure that the controller processes personal data in compliance with the provisions of data protection law, and in the event of the Personal Data Guardian identifying any violation regarding this matter, he shall immediately bring it to the attention of the controller to eliminate the causes of violation or undertake the necessary rectification as soon as possible 4. notify the authority upon obtaining new evidence concerning the committed violations which the controller has not yet rectified nor eliminated its causes, after a period exceeding ten days from his notification thereof 5. maintain the RoPA.	In all countries, DPO tasks are similar. Interesting exception is the Bahrain data protection law, which mandates to share evidences with the Authority, if the controller did not rectify its wrongful privacy practices.

Data Breach

	EU	UAE (Federal Law)	DIFC	ADGM	KSA	Qatar	Oman	Bahrain	WLC Remarks
Definition	A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed.	Breaching information security and Personal data through illegal or unauthorized access. This includes copying, sending, distributing, exchanging, transferring, circulating or processing it in a way which leads to disclosure of such data to third parties, or destroying or modifying it during storage, transfer and processing.	A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, Personal data transmitted, stored or otherwise Processed.	A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed.	Any incident that leads to the disclosure, destruction, or unauthorized access to personal data, whether intentional or accidental, and by any means, whether automated or manual.	The law does not provide a definition for data breach , but guideline provided on data breaches by supervisory authority provides that a personal data breach means a breach of security leading to the unlawful or accidental alteration, destruction, loss, unauthorised disclosure of, or access to, personal data. This includes both accidental and deliberate breaches.	Unlawful access to personal data leading to its unauthorised destruction, alteration, disclosure, access, or processing.	The law does not provide a definition for data breach.	
Deadline to Report	🟢 72 hours after becoming aware of the incident.	Immediately upon becoming aware of such breach (the period is to be specified in Executive Regulations).	As soon as practicable in the circumstances.	🟢 72 hours after becoming aware of the incident.	🟢 72 hours after becoming aware of the incident.	72 hours after becoming aware of the incident, but this deadline is specified by a Data Breach Guideline .	🟢 72 hours after becoming aware of the incident.	🟢 72 hours after becoming aware of the incident, but this deadline is specified by an Order No. (43) of 2022.	UAE Federal Law, DIFC, Bahrain and Qatar data protection laws don't have specific deadline regarding data breach reporting. Still, in some cases (e.g. Bahrain, Qatar) such deadlines may be specified by other regulations or guidelines issued by relevant authorities.

Enforcement

	EU	UAE (Federal Law)	DIFC	ADGM	KSA	Qatar	Oman	Bahrain	WLC Remarks
Authorities	Local authorities in the EU member states; European Supervisory Authority; European Data Protection Board.	UAE Data Office established under Federal Decree by Law No. (44) of 2021.	DIFC Commissioner of Data Protection appointed by the President of the DIFC to administer the Law.	ADGM Office of Data Protection, which includes the Commissioner of Data Protection, any deputy commissioners and other officers or Staff of the Commissioner of Data Protection.	Saudi Authority for Data and Artificial Intelligence.	National Cyber Governance and Assurance Affairs.	The Ministry of Transport, Communications and Information Technology.	Personal Data Protection Authority of Bahrain.	
Fines	4% global revenue or €20 million, whichever is higher.	No information (the details is to be specified in Executive Regulations).	Fines differ, but the maximum is \$100 000, which can be imposed, for example, in case of infringement of data subjects' rights.	Up to \$28 million.	In case of a disclosure or publication of sensitive personal data, a fine may be issued not exceeding SAR 3 million. In case of violation of requirements with regard to data transfers, a fine may be issued in the amount not exceeding SAR 1 million. For violations of other provisions of the PDPL, penalties are limited to a warning notice or can result in a fine not exceeding SAR 5 million.	Fines differ depending on violated articles. The authority may issue a fine of up to 5 million QR for violations related to security of personal data, violations related to processing of personal data of special nature or children's data.	Fines differ depending on violated articles. The authority may issue a fine of up to OMR 500,000. Violation of data protection requirements may in some cases also lead to imprisonment of up to 1 year in accordance with the penal law.	Fines differ, but the authority may issue administrative fines ranging from BD 1000 to BD 20,000. In certain circumstances, a breach of data protection law may lead to imprisonment of up to 1 year .	
Private right of action	Data subjects may claim compensation for material and non-material damage against controllers or processors.	Individuals can file complaints through the UAE Data Office if they believe that there is a violation of the Law or that the controller or the processor is processing their Personal data in violation of the rules and procedures set by the UAE Data Office in this regard.	A data subject who suffers material or non-material damage by reason of any contravention of the law or the regulations may apply to the court for compensation from the controller or processor in question, in addition to, and exclusive of, any fine imposed on the same parties under article 62 of the Law.	Any person who has suffered material or non-material damage as a result of a contravention of these Regulations is entitled to compensation from the controller or processor for the damage suffered. Any compensation is in addition to, and will not limit, any fine imposed on the same controller or processor.	Data subjects can claim damages for material and non-material loss in relation to breaches of any provisions of the law and/or the Regulations.	The law does not provide for any private right of action.	The law does not provide for any private right of action.	Any party who suffers damage resulting from processing of his personal data by the Data Controller, or as a result of violating provisions of this Law by Data protection Guardian, is entitled to claim compensation from the Data Controller or Data protection Guardian.	

Authors



Nicholai Pfeiffer

Managing Partner
White Label Consultancy

np@whitelabelconsultancy.com



Dr. Magdalena Goralczyk

Data Protection Partner
White Label Consultancy

mg@whitelabelconsultancy.com



Przemyslaw Gruchala

Senior Consultant
White Label Consultancy

pgr@whitelabelconsultancy.com



Norman Aasma

Associate
White Label Consultancy

noa@whitelabelconsultancy.com



Lucrezia Nicosia

Consultant
White Label Consultancy

lni@whitelabelconsultancy.com